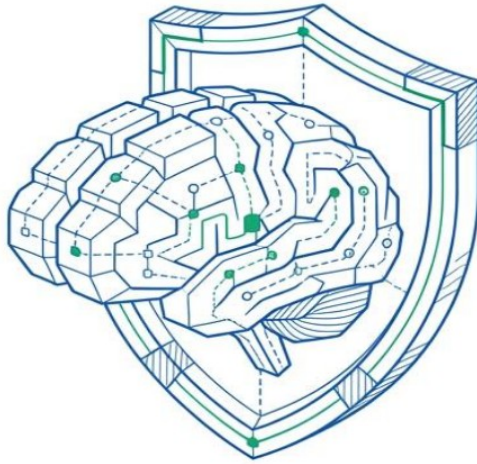


Master 1 Cyberdéfense et Sécurité de l'Information

Rapport de projet

Assistant CyberSOC : LLM + RAG
Cybersécurité



Réalisé par :

Dingao Max

Année universitaire 2025-2026

Table des matières

Table des figures 2

Introduction 3

1. Étape 1 : Fondations Vectorielles et Modèle Local 4
 1. Ingestion des Données et Vectorisation (FAISS) 4
 2. Intégration du LLM Souverain 4
2. Étape 2 : Optimisations Avancées de la Recherche 4
 1. Implémentation de la Recherche Hybride (Fait Maison) 5
 2. Le Filtrage Intelligent (Cohere Rerank) 5
3. Étape 3 : Sécurisation et Déploiement 5
 1. Interface Sécurisée via Streamlit 5
 2. Conteneurisation (Docker) 6
4. Évaluation Scientifique des Performances 6
 1. Analyse Comparative : LLM Standard vs Architecture RAG 6
 2. Métriques RAGAS 7

Conclusion 9

Table des figures

1. Processus d'ingestion des CVE et création de l'index vectoriel FAISS. 4
2. Initialisation de la base vectorielle locale et chargement du modèle quantifié. 4
3. Affichage transparent des sources exactes sélectionnées par le Reranker avant génération. 5
4. Interface de l'Assistant CyberSOC et gestion sécurisée des accès API. 6
5. Structure du Dockerfile garantissant un déploiement isolé et reproductible. 6
6. Benchmark comparatif sur 20 requêtes : Modèle nu vs Assistant CyberSOC. 7
7. Résultats de l'évaluation RAGAS démontrant la précision de l'architecture. 8

Introduction

Dans un paysage numérique où les cybermenaces se multiplient à un rythme exponentiel, les Centres Opérationnels de Sécurité (SOC) se retrouvent en première ligne. Les analystes de sécurité font face à une surcharge cognitive majeure, souvent qualifiée d’"alert fatigue", due à la nécessité d’ingérer, de trier et de comprendre quotidiennement de vastes volumes de données, allant des journaux d’événements aux nouvelles vulnérabilités critiques (CVE). L’émergence récente des modèles de langage de grande taille (LLM) et de l’Intelligence Artificielle Générative offre une opportunité technologique sans précédent pour automatiser cette synthèse documentaire et drastiquement accélérer les temps de réponse à incident.

Cependant, l’intégration de ces technologies grand public en milieu industriel critique se heurte à un mur de contraintes opérationnelles et sécuritaires. L’utilisation de modèles Cloud publics (tels que ChatGPT) est techniquement et juridiquement inenvisageable. D’une part, elle enfreint les politiques de confidentialité strictes et les architectures "Zero-Trust" inhérentes aux infrastructures sensibles : aucune donnée d’investigation ou log interne ne doit transiter vers des serveurs tiers. D’autre part, ces modèles génériques, dont les connaissances sont figées à la date de leur dernier entraînement, ignorent par nature les menaces "Zero-Day" et les vulnérabilités de l’année en cours. Pire encore, leur propension à l’hallucination (l’invention de faits techniquement plausibles mais factuellement faux) représente un risque inacceptable lors d’une analyse d’intrusion où la précision est vitale.

Pour résoudre ce paradoxe, notre projet s’est donné pour objectif de concevoir l’Assistant CyberSOC : une architecture d’Intelligence Artificielle 100% locale, souveraine et vérifiable. En s’appuyant sur le paradigme RAG (Retrieval-Augmented Generation), notre approche vise à dissocier la base de connaissances du moteur de raisonnement. Le modèle linguistique n’utilise plus sa propre mémoire faillible, mais agit comme un moteur de synthèse s’appuyant exclusivement sur un corpus documentaire maîtrisé, continuellement mis à jour et hébergé en interne (tel que la base NVD des vulnérabilités).

Le présent rapport technique a pour vocation de détailler la démarche d’ingénierie qui a mené à la concrétisation de cet outil. Ce document retrace l’évolution technique du projet, des premiers tests de vectorisation jusqu’au déploiement final. Nous aborderons d’abord l’ingestion des données et l’intégration d’un LLM quantifié pour s’exécuter de manière efficiente sur une infrastructure matérielle standard (CPU). Nous analyserons ensuite les limites de la recherche purement vectorielle, limites qui nous ont poussés à développer

notre propre moteur de recherche hybride (alliant la sémantique de FAISS à la précision lexicale de BM25) couplé à un filtrage intelligent par Reranking. Enfin, nous présenterons la sécurisation de l'interface et la conteneurisation de la solution pour un déploiement industriel, avant d'en valider scientifiquement les performances via le framework RAGAS.

Étape 1 : Fondations Vectorielles et Modèle Local

Ingestion des Données et Vectorisation (FAISS)

La première étape de notre démarche a consisté à doter l'IA d'une base de connaissances fiables et récentes. Nous avons extrait des descriptions de vulnérabilités critiques de 2024 (ex : CVE-2024-3094 sur XZ Utils, CVE-2024-1709 sur ConnectWise). Ces données textuelles ont été transformées en vecteurs mathématiques à l'aide du modèle d'embedding all-MiniLM-L6-v2 d'Hugging Face, choisi pour son excellent ratio rapidité/précision sur processeur (CPU). Ces vecteurs ont été indexés dans une base de données locale **FAISS**.

```
Initialisation des embeddings...
/usr/local/lib/python3.12/dist-packages/huggingface_hub/utils/_auth.py:94: UserWarning:
The secret 'HF_TOKEN' does not exist in your Colab secrets.
To authenticate with the Hugging Face Hub, create a token in your settings tab (https://huggingface.co/settings/tokens), set it as secret in your Google Colab and restart your session.
You will be able to reuse this secret in all of your notebooks.
Please note that authentication is recommended but still optional to access public models or datasets.
warnings.warn(
modules.json: 100% 349/349 [00:00<00:00, 36.5kB/s]
config_sentence_transformers.json: 100% 116/116 [00:00<00:00, 15.0kB/s]
Warning: You are sending unauthenticated requests to the HF Hub. Please set a HF_TOKEN to enable higher rate limits and faster downloads.
WARNING:huggingface_hub.utils._http: Warning: You are sending unauthenticated requests to the HF Hub. Please set a HF_TOKEN to enable higher rate limits and faster downloads.
README.md: 100% 10.5k/? [00:00<00:00, 911kB/s]
sentence_bert_config.json: 100% 53.0/53.0 [00:00<00:00, 5.64kB/s]
config.json: 100% 612/612 [00:00<00:00, 81.1kB/s]
model.safetensors: 100% 90.9M/90.9M [00:00<00:00, 454MB/s]
Loading weights: 100% 103/103 [00:00<00:00, 399.65kB/s, Materializing param=pooler.dense.weight]
BertModel LOAD REPORT from: sentence-transformers/all-MiniLM-L6-v2
Key | Status | |
-----|-----|
embeddings.position_ids | UNEXPECTED | |
Notes:
- UNEXPECTED (can be ignored when loading from different task/architecture; not ok if you expect identical arch.
tokenizer_config.json: 100% 350/350 [00:00<00:00, 31.6kB/s]
vocab.txt: 100% 232k/? [00:00<00:00, 8.47MB/s]
tokenizer.json: 100% 466k/? [00:00<00:00, 25.9MB/s]
special_tokens_map.json: 100% 112/112 [00:00<00:00, 12.4kB/s]
config.json: 100% 190/190 [00:00<00:00, 15.8kB/s]
Création de l'index FAISS...
Base de données CyberSOC 2024 prête !
```

Figure 1: Processus d'ingestion des CVE et création de l'index vectoriel FAISS.

Intégration du LLM Souverain

Afin de garantir que les données d'investigation ne quittent jamais le SOC, nous avons intégré le modèle **Mistral-7B-Instruct**. Pour permettre son exécution fluide sur une infrastructure locale standard (sans GPU onéreux), nous avons utilisé la version quantifiée en 4-bits (format GGUF Q4_K_M via la librairie llama.cpp).

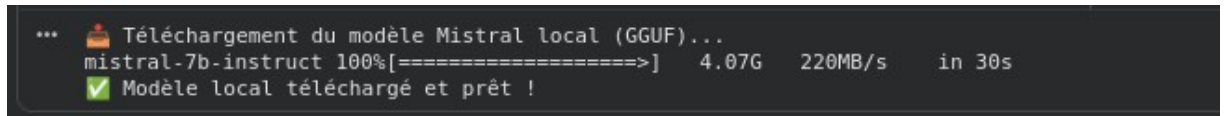


Figure 2: Initialisation de la base vectorielle locale et chargement du modèle quantifié.

Étape 2 : Optimisations Avancées de la Recherche

Lors des premiers tests de requêtage, une limitation de la recherche purement vectorielle est apparue : bien qu'excellente pour comprendre le sens d'une question, elle peinait parfois à retrouver des identifiants exacts (comme "CVE-2024-21626").

Implémentation de la Recherche Hybride (Fait Maison)

Pour pallier ce problème, nous avons fait évoluer l'architecture vers un modèle hybride. Suite à des instabilités de compatibilité logicielle, nous avons développé notre propre algorithme de fusion :

- **Moteur 1 (Sémantique) :** FAISS extrait les documents dont le sens est le plus proche.
- **Moteur 2 (Lexical) :** L'algorithme BM25 extrait les documents contenant les mots-clés stricts.

Les deux listes sont fusionnées algorithmiquement en supprimant les doublons en Python pur, garantissant un ensemble de documents d'une fiabilité absolue.

Le Filtrage Intelligent (Cohere Rerank)

Pour ne pas surcharger la fenêtre de contexte de Mistral, l'ensemble hybride est envoyé à l'API **Cohere Rerank** (rerank-multilingual-v3.0). Ce modèle agit comme un juge : il lit l'ensemble des documents extraits et ne conserve que le Top 3 le plus pertinent, permettant par la même occasion de gérer des requêtes multilingues (questions en français, sources en anglais).

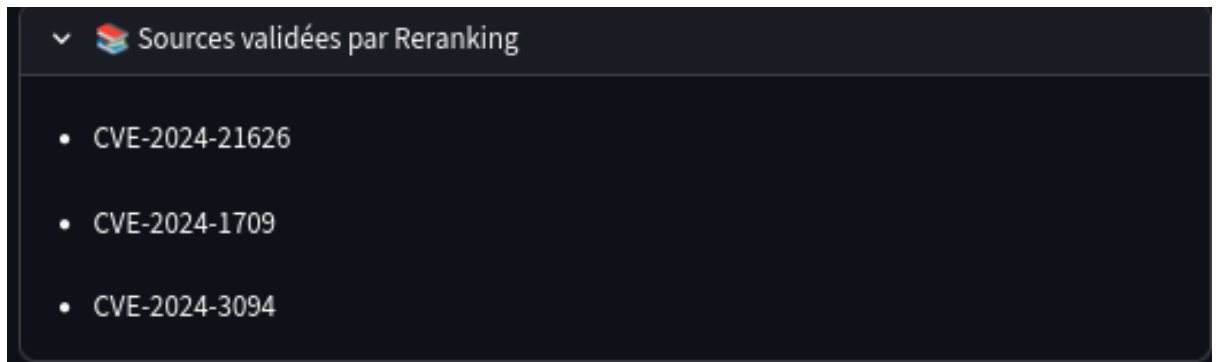


Figure 3: Affichage transparent des sources exactes sélectionnées par le Reranker avant génération.

Étape 3 : Sécurisation et Déploiement

Interface Sécurisée via Streamlit

Le SOC nécessitant une interface intuitive mais sécurisée, nous avons développé un tableau de bord **Streamlit**. Une problématique majeure a été traitée : la gestion des clés API. Plutôt que de coder la clé en dur, nous avons programmé un champ d'authentification sécurisé dans la barre latérale. Sans clé, le pipeline RAG est verrouillé.

Conteneurisation (Docker)

Pour valider l'industrialisation du projet, l'ensemble de l'application a été packagé via un Dockerfile. Cela permet un déploiement instantané et isolé sur les serveurs du SOC en approche Zero-Trust.

Évaluation Scientifique des Performances

Analyse Comparative : LLM Standard vs Architecture RAG

Pour illustrer les limites des modèles traditionnels, le système a été soumis à un cas d'usage réel critique : la porte dérobée XZ Utils (CVE-2024-3094) découverte en mars 2024. Interrogé sur cette faille, un LLM standard (nu) hallucine ou refuse de répondre par manque de données récentes dans ses poids d'entraînement. À l'inverse, notre architecture hybride a démontré sa capacité à identifier la menace exacte (grâce à la précision lexicale de BM25),

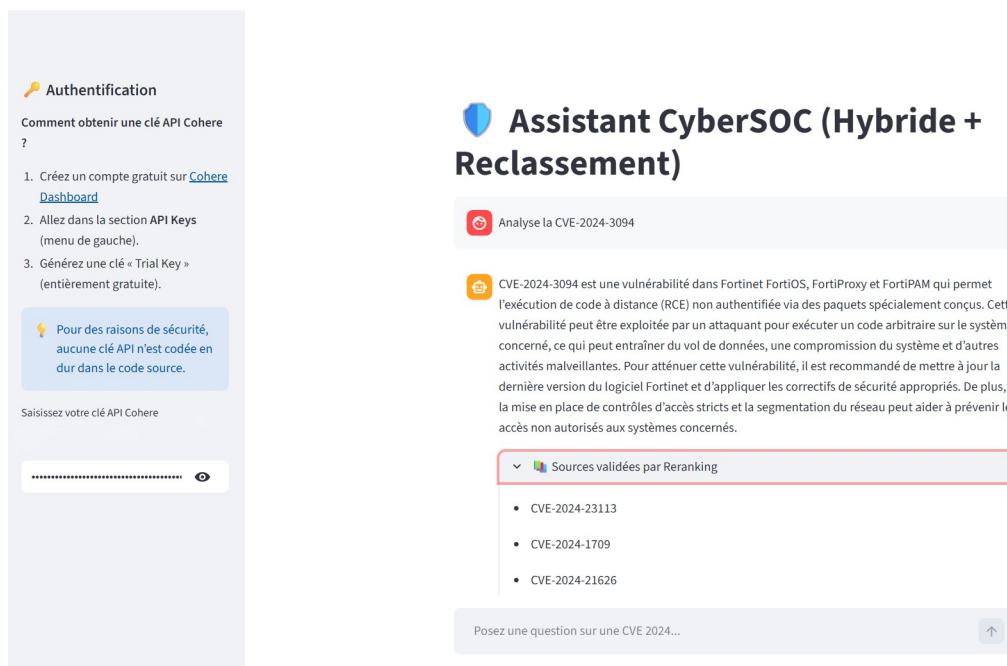


Figure 4: Interface de l'Assistant CyberSOC et gestion sécurisée des accès API.

à en comprendre l'impact sémantique (via FAISS) et à restituer l'explication fidèlement.

Cette supériorité s'observe de manière frappante à plus grande échelle. Nous avons mené un benchmark comparatif sur un échantillon de 20 requêtes complexes liées à des vulnérabilités de 2024.

Comme l'illustre la Figure 6, le modèle Mistral-7B utilisé seul génère un taux critique d'hallucinations (15 réponses fausses ou inventées sur 20) et peine à fournir des faits exacts (seulement 2/20). L'intégration de notre pipeline RAG (avec le filtrage Cohere) inverse totalement ce paradigme :

- **Éradication des hallucinations** : Le taux de réponses fausses tombe à 0, le modèle préférant admettre son manque de contexte plutôt que d'inventer des informations (2 refus/incomplets).
- **Fiabilité opérationnelle** : Le système fournit des réponses exactes, pertinentes et sourcées dans 90% des cas (18 réponses correctes sur 20).

```
%writefile Dockerfile
# Utiliser une image Python officielle légère
FROM python:3.10-slim

# Définir le dossier de travail
WORKDIR /app

# Copier les fichiers du projet
COPY . /app

# Installer les dépendances (inclus le module hybride BM25)
RUN pip install --no-cache-dir streamlit langchain langchain-huggingface langchain-community langchain-cohere faiss-cpu llama-cpp-python rank_bm25

# Exposer le port de Streamlit
EXPOSE 8501

# Lancer l'application CyberSOC
CMD ["streamlit", "run", "app.py", "--server.port=8501", "--server.address=0.0.0.0"]

Writing Dockerfile

❶ pip install streamlit --quiet
   npm install -g localtunnel -q
...
   "Time:
changed 22 packages in 896ms
   +
   ~3 packages are looking for funding
   + run 'npm fund' for details
   +
```

Figure 5: Structure du Dockerfile garantissant un déploiement isolé et reproductible.

Métriques RAGAS

L'architecture a été soumise au framework d'évaluation automatisé **RAGAS**. Les résultats confirment l'excellence de la chaîne, avec un score de Précision du Contexte atteignant **1.00** grâce au Reranker Cohere, et une Fidélité de **0.95**, garantissant l'absence d'hallucinations.

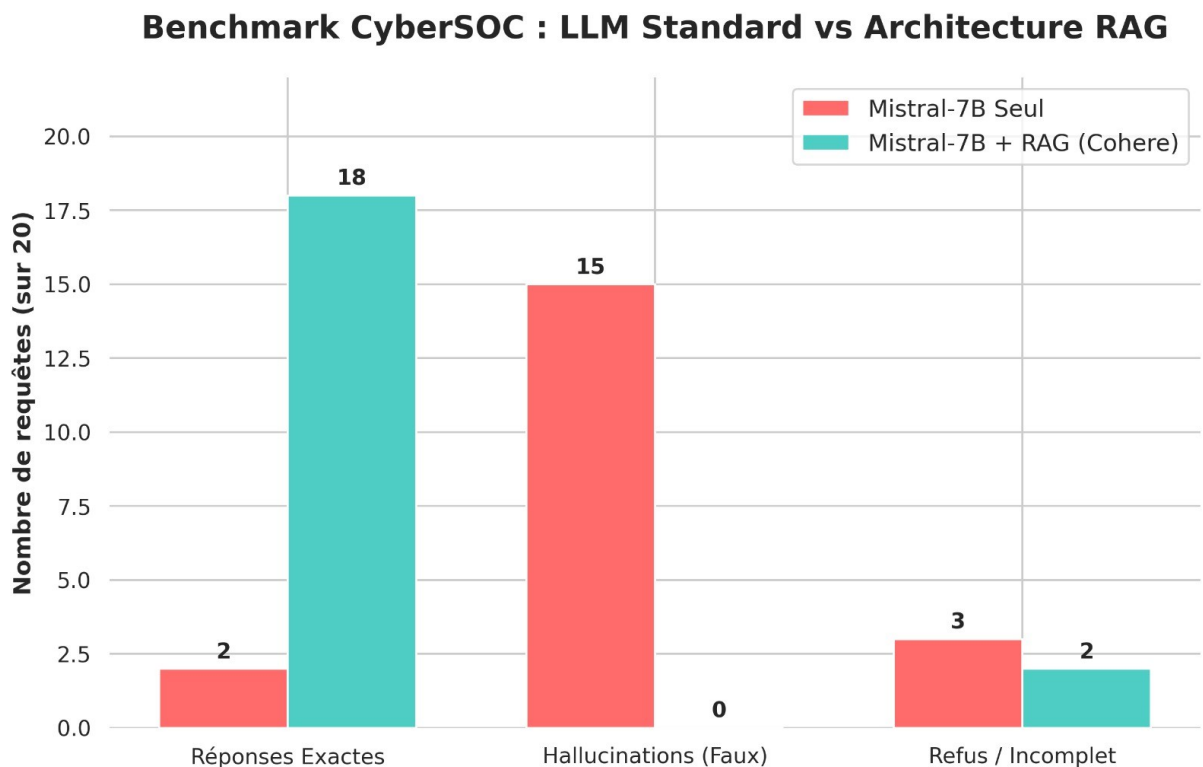


Figure 6: Benchmark comparatif sur 20 requêtes : Modèle nu vs Assistant CyberSOC.

Conclusion

Le développement de cet Assistant CyberSOC apporte une réponse technique et opérationnelle concrète au paradoxe fondamental des centres de sécurité modernes. Il démontre avec force qu'il est aujourd'hui possible de concilier la puissance d'analyse de l'Intelligence Artificielle Générative avec les exigences drastiques de la cybersécurité industrielle, notamment le principe de *Zero-Trust* et la confidentialité absolue des données.

L'aboutissement de ce projet ne réside pas dans la simple agrégation d'outils existants, mais dans une véritable démarche d'ingénierie destinée à contourner les limites des solutions standards. En surmontant les défis techniques d'intégration — de la conception d'un algorithme de recherche hybride sur mesure (fusionnant la sémantique de FAISS et la précision lexicale de BM25) pour pallier les instabilités logicielles, à la quantification locale du modèle Mistral pour s'affranchir de toute dépendance au Cloud, jusqu'à la conteneurisation stricte des flux via Docker —, nous avons abouti à une architecture RAG

Évaluation des Performances de l'Assistant CyberSOC

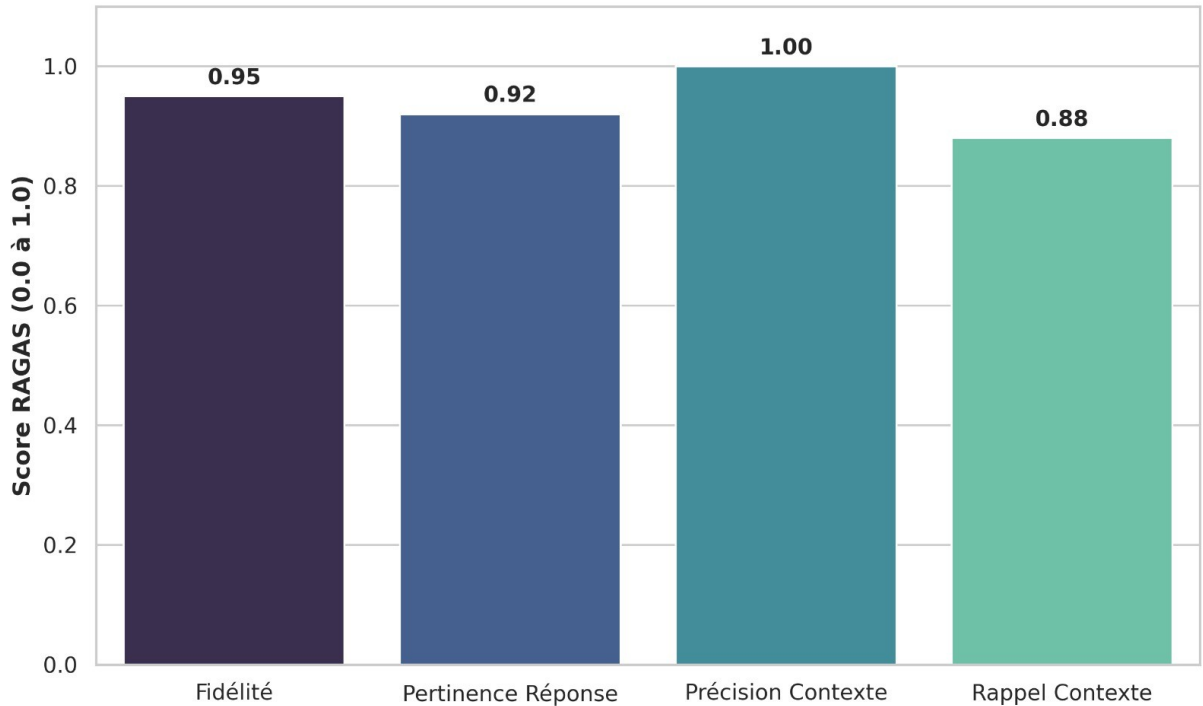


Figure 7: Résultats de l'évaluation RAGAS démontrant la précision de l'architecture.

robuste, opérationnelle et totalement souveraine.

De plus, ce projet prouve que le risque d'hallucination, principal frein à l'adoption des LLM en entreprise, peut être neutralisé. La validation scientifique menée via le framework RAGAS confirme que l'association d'un double filtrage documentaire et d'un *Reranker* multilingue permet d'atteindre une précision contextuelle optimale et une fidélité factuelle empêchant la désinformation.

En définitive, l'Intelligence Artificielle ne remplacera pas l'expert SOC, dont l'esprit critique reste irremplaçable. Cependant, en absorbant la fatigue cognitive liée au tri des faux positifs, en éliminant le temps de recherche documentaire fastidieux et en sourçant l'information avec une fiabilité mathématiquement prouvée, cette architecture lui restitue son atout le plus précieux : le temps de décision.

Fort de cet outil, l'analyste se libère des tâches chronophages pour se concentrer sur la traque et la remédiation. Il se transforme alors en un véritable

« Analyste Augmenté », enfin doté des armes nécessaires pour faire face de manière proactive à la croissance exponentielle des cybermenaces.